



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Operating systems hardening and Buffer Overflow Attacks

materials are partly from security courses at other institutions



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Virus, Worm, Trojan

based on materials obtained from the Internet

Definitions



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Virus
 - malicious code that **copies** itself into other programs.
- Worm
 - a program that replicates itself across the **network** (usually riding on email messages or attached documents (e.g., macro viruses)).
- Trojan Horse
 - Instructions in an otherwise **good program** that **cause bad** things to happen (sending your data or password to an attacker over the net).
- Others:
 - Logic Bomb - malicious code that activates **on an event** (e.g., date).
 - Trap Door (or Back Door) - an undocumented entry point written into code for debugging that can **allow** unwanted users.
 - Easter Egg - extraneous code that does something “**cool**.” A way for programmers to show that they control the product.

Virus

1. What is a Virus
2. Goal of Viruses
3. Types
4. Virus Detection



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

What exactly is a Virus



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Small program that negatively alters the way a computer works
- Self replicating
- Done without user knowledge or intervention
 - still needs to be activated initially by the user

Virus

1. What exactly is a Virus
2. Goal of Viruses
3. Types
4. Virus Detection



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Goal of Viruses



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Ultimate goal is to **spread as far as possible** (both on the box and globally) before being wiped out

Virus

1. What exactly is a Virus
2. Goal of Viruses
3. Types
4. Virus Detection



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Types

- System sector/Boot viruses
 - Infect the system sectors of disks & hard drives, e.g., VMM virus
- File/Parasitic viruses
 - .COM and .EXE files, most typical
- Batch file & Macro viruses
 - Use text batch files or Word/Excel macros

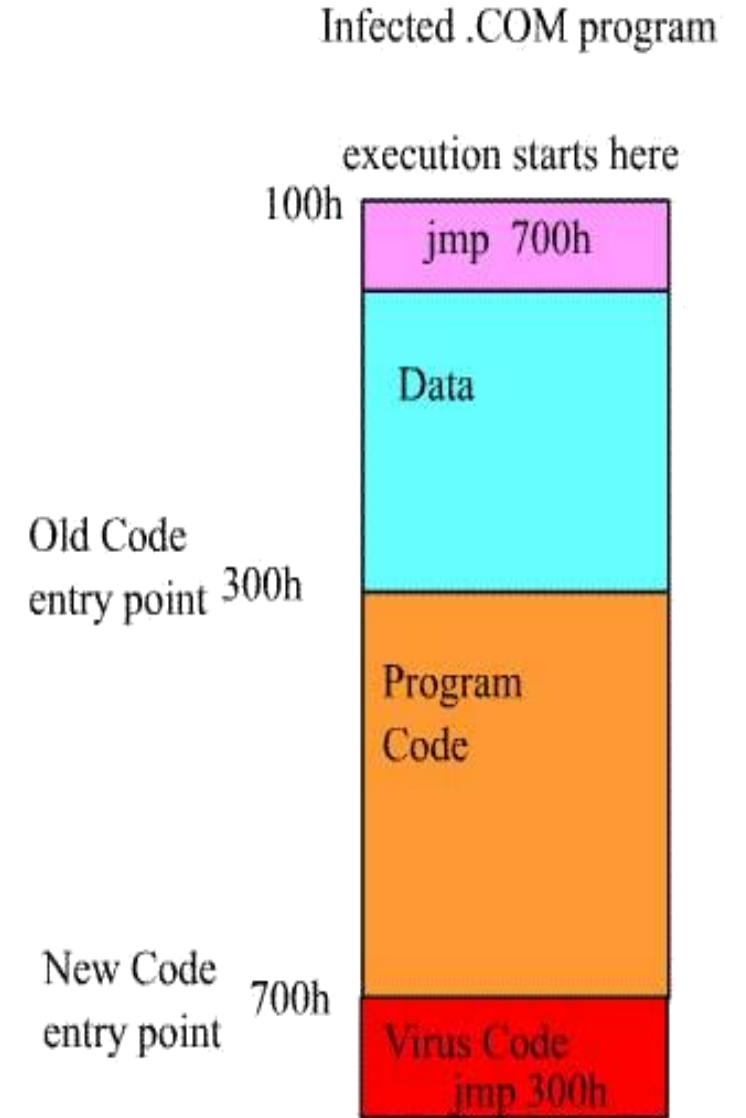
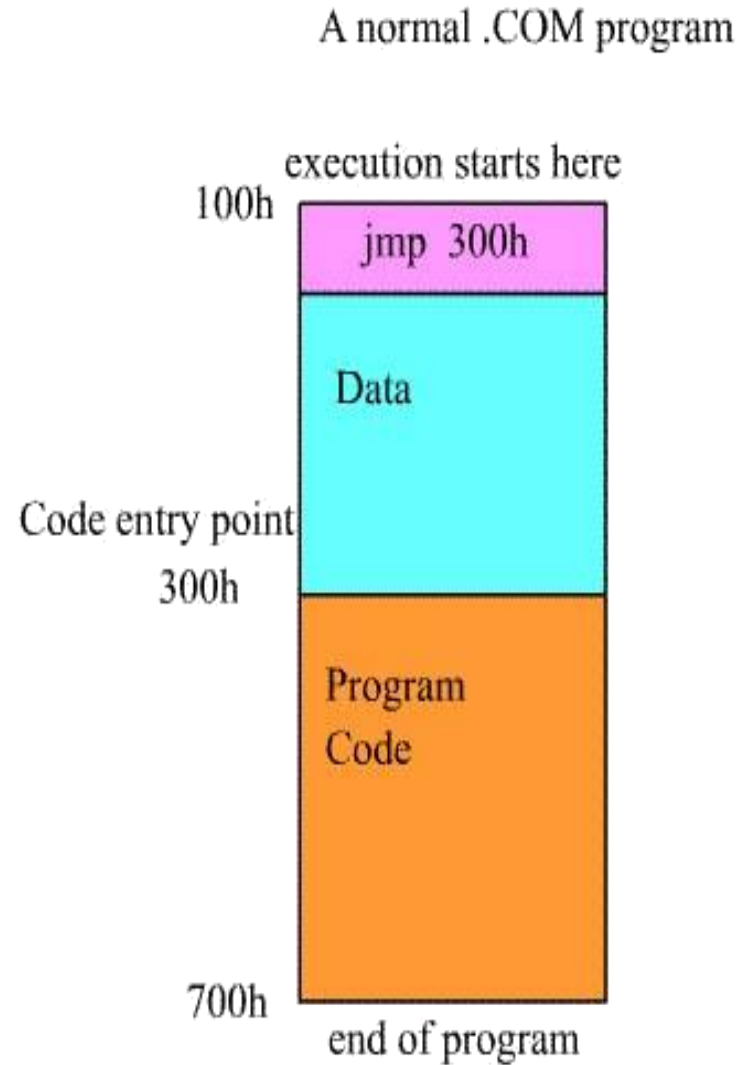
... ..



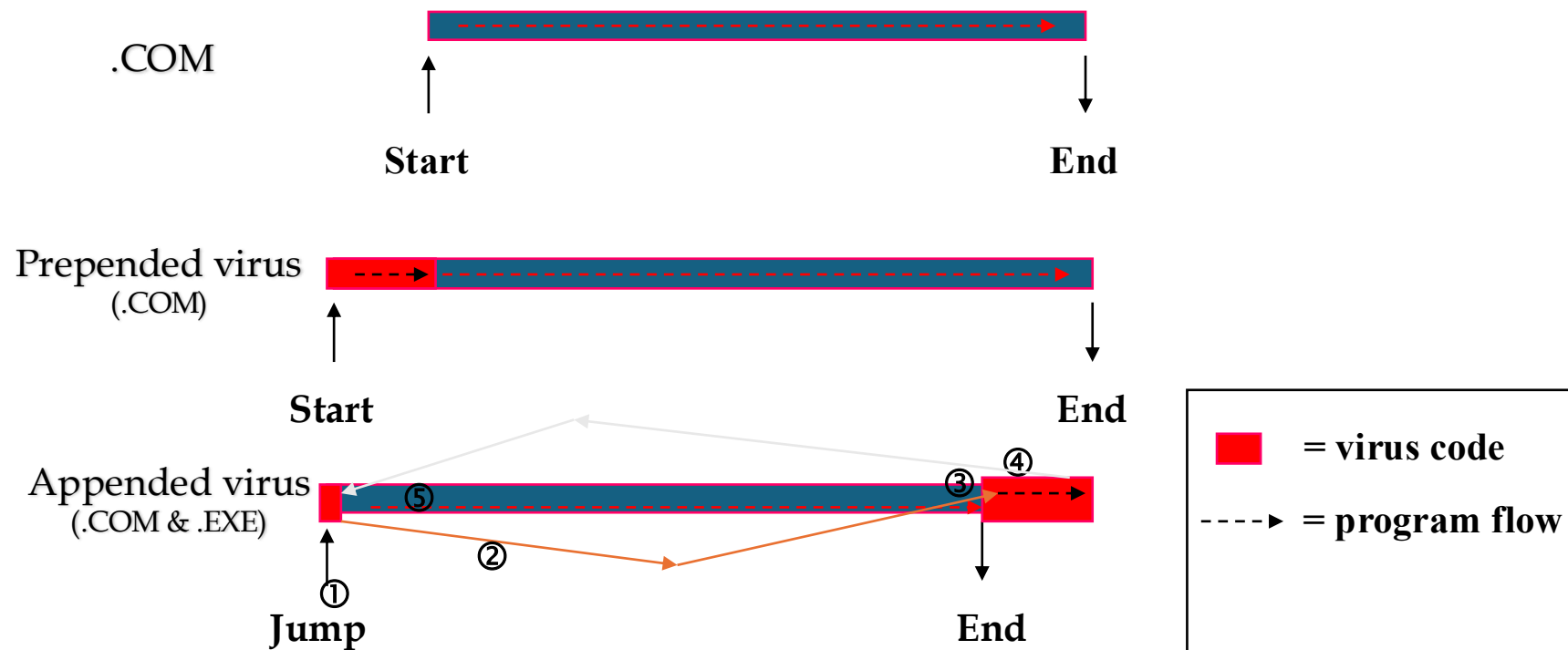
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Parasitic Viruses

- Simple File Viruses
 - After transplanting itself in the executable, the executable often doesn't work
- Stealth Component
 - Work very similar to stealth system sector viruses
- Mask the file size of infected files when a directory listing is done on them



File Infectors



Virus

1. What exactly is a Virus
2. Goal of Viruses
3. Types
4. Virus Detection



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Virus Detection



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- 1st Generation, Scanners: searched files for any of a library of known virus “**signatures**.” Checked executable files for length changes.
- 2nd Generation, Heuristic Scanners: looks for **more general signs** than specific signatures (code segments common to many viruses). Checked files for checksum or hash changes.
- 3rd Generation, Activity Traps: **stay** resident in memory and look for certain patterns of software behavior (e.g., scanning files).
- 4th Generation, Full Featured: **combine** the best of the techniques above.

Worms



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

1. Definition
2. Differences between Worms and Virus
3. Popular Worms: Lion Worm and Code Red Infection

Worms



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Similar to a virus, but propagates itself through the Internet by breaking into machines
- Main goal is to bring down and deny access to networks and services
 - Does not rely on user intervention
 - Does not rely on being transmitted physically (i.e. by disk)
 - Does not rely on being emailed or transferred by the *user* – does it by itself

Worms



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- A worm is a self propagating piece of malicious software. It attacks vulnerable hosts, infects them, then uses them to attack other vulnerable hosts
- “Famous” Worms
 - Morris Internet worm (1988)
 - Ramen Worm
 - **Lion worm**
 - Adore Worm
 - **Code Red**
 - Nimda

Worms



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

1. Definition
2. Differences between Worms and Virus
3. Popular Worms: Lion Worm and Code Red Infection

Worms

- Worms vs. Viruses
 - Viruses require interaction
 - Worms act on their own
 - Viruses use social attacks
 - Worms use technical attacks



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Lion Worm in Linux

- Exploits buffer overflow in BIND to gain root access
- Listens on port 27374
- Sends out email to huckit@china.com with /etc/passwd, /etc/shadow and network settings
- Randomly generates class B network addresses to scan
- Scans network for exploitable hosts



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Code Red Infection



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Exploits the buffer overflow vulnerability associated with "idq.dll". idq.dll provides support for internet data administrative script files ".ida" and internet data queries files ".idq" for indexing server 2.0 and indexing services.
- The malicious code is not saved as a file but is inserted into and then run directly from memory.

Propagation



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- If the file C:\Notworm does not exist, then new threads are created. If the date is before the 20th of the month, the next 99 threads attempt to exploit more computers by targeting random IP addresses.
- The worm sends its code as an HTTP request. The HTTP request exploits a known buffer-overflow vulnerability, which allows the worm to run on remote computer.

Attacks



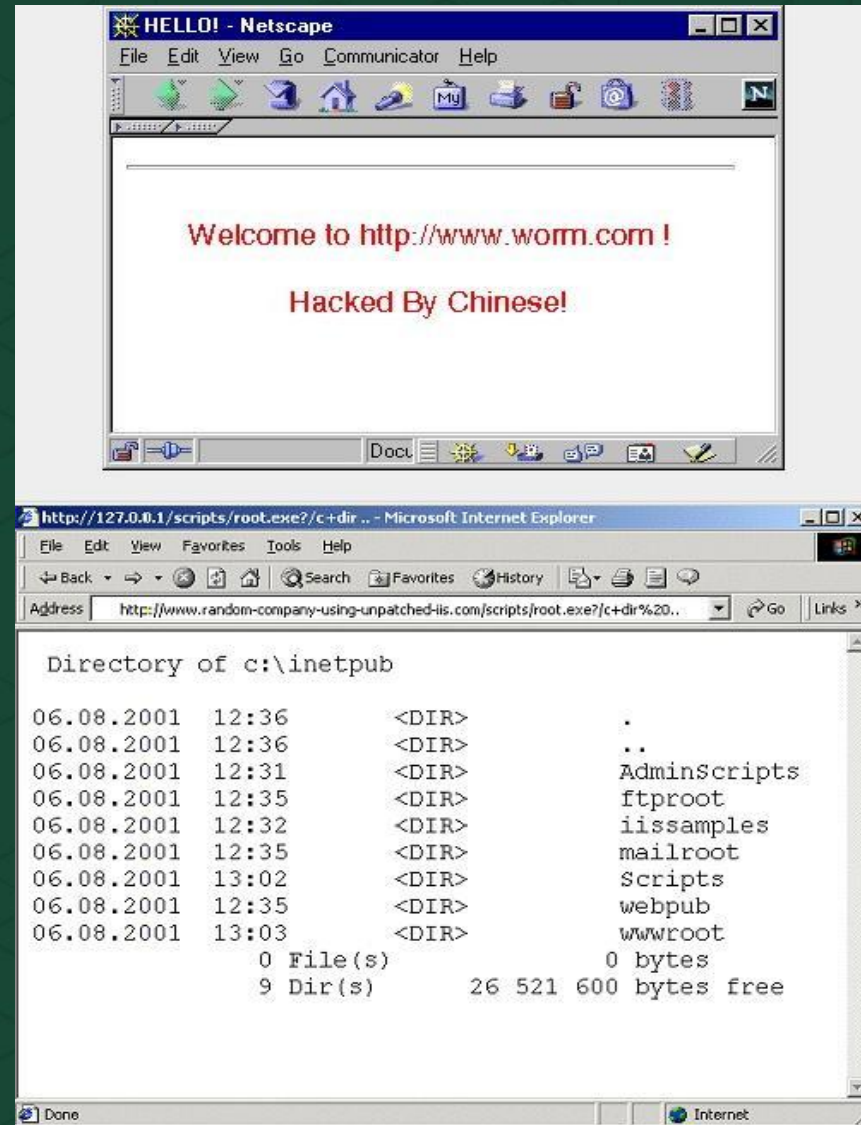
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Denial of Service by sending large amounts of junk data to port 80 (Web service) of 198.137.240.91, which was www.whitehouse.gov. This IP address has been changed and is no longer active.
- If the default language of the computer is U.S. English, further threads cause Web pages to appear defaced. First, the thread sleeps two hours and then hooks a function, which responds to HTTP requests. Instead of returning the correct Web page, the worm returns its own HTML code. web page delivery

Code Red



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



Code Red in Windows

- Code Red infected over 250,000 systems in 9 hours on July 19, 2001.
- Code Red worms cost business few billion dollars.



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Trojan

1. Definition
2. Example



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Trojan

- A small program that is designed to appear desirable but is in fact malicious
- Must be run by the user
- Do not replicate themselves
- Used to take over a computer, or steal/delete data
- Install backdoors, perform malicious scanning, monitor system logins and other malicious activities.



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Back Orifice 2000/BO2k



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- A “Remote Administration” tool for windows 9x and NT.
 - Runs on remote system without user knowing
 - can control several servers simultaneously
- Allows complete control over server system including logging all keystrokes at the console. (Passwords, email, etc)
- By default server listens on tcp 54320 or udp 54321

Back Orifice 2000/BO2k



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- It sets itself to be automatically run, by modifying the following Windows registry:
 - HKEY_LOCAL_MACHINE\software\Microsoft\Windows\CurrentVersion\vmgr.exe
 - The "Data" field of this registry entry is set to, "c:\Windows\vmgr.exe".
- Due to this, the Trojan is run at every Windows start-up.

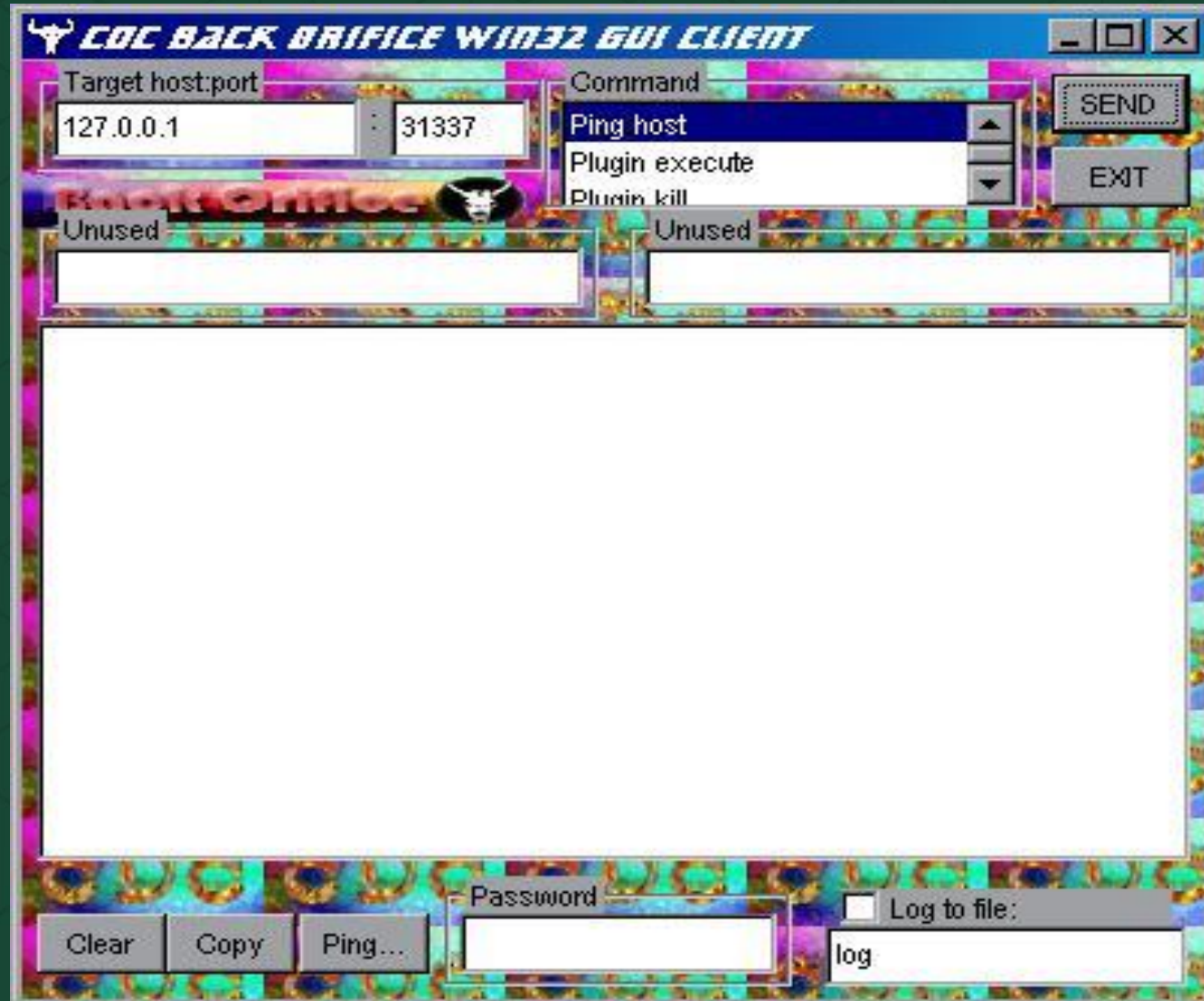
Back Orifice/BO2k



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- It can:
 - Besides opening and closing the CD drawer,
 - turn on the microphone and record conversations
 - Turn on camera to record occurrences in room
 - create or modify registry keys
 - Log keystrokes
 - Create dialog boxes and type messages
 - reboot the machine
 - Get detailed system information
 - Gather passwords (Screensaver, Dialup, Network access)
 - Dumps hashed NT passwords from SAM database (for later cracking in L0phtCrack)
 - Copy, rename, delete, view, and search files and directories, even change share attributes.

BO2k Control Box



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Anti-Virus

- Detection
 - Infected or not? Provably undecidable...
- Disinfection
 - Remove the virus



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Static Detection

- Detection without running virus code
- Three approaches...
 1. **Scanners**
 - Signature (our focus)
 2. Heuristics
 - Look for “virus-like” code
 3. Integrity Checkers
 - Hash/checksum



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Scanners

- On-demand
 - Files scanned when you say so
- On-access
 - Constant scanning in background
 - Whenever file is accessed, it's scanned
- Signature scanning
 - Viruses represented by “signature”
 - Signature == pattern of bits in a virus (might include wildcards)
 - “Hundreds of thousands of signatures”, not feasible to scan one-by-one



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Algorithm: Aho-Corasick (not required in hw/exam)

- Developed 1975, bibliographic search
- Based on finite automaton (graph)
 - Circles are search states
 - Edges are transitions
 - Double circles are final states/output
- And a failure function
 - What to do when no suitable transition
 - I.e., where to resume “matching”

Aho-Corasick

- ***Linear*** search that can find multiple signatures
 - Like searching in parallel for related signatures
- Efficient representation of automaton is the challenge
 - Both time and space issues



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Algorithm: Aho-Corasick

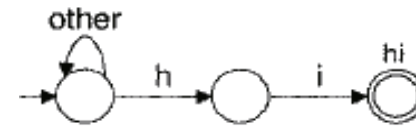
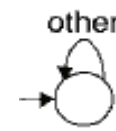
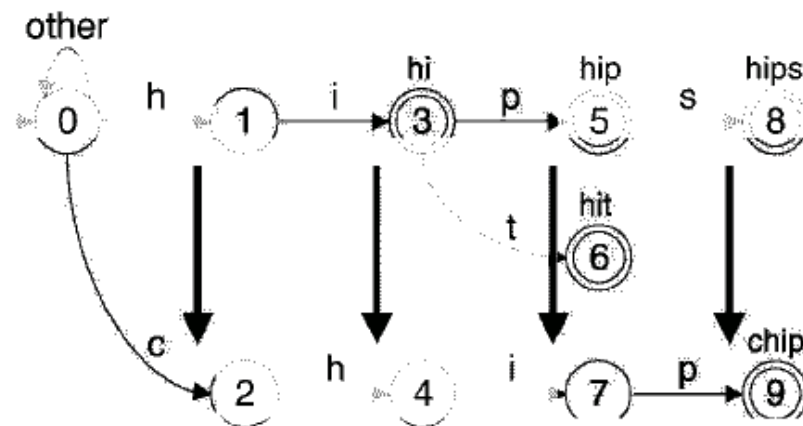


MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

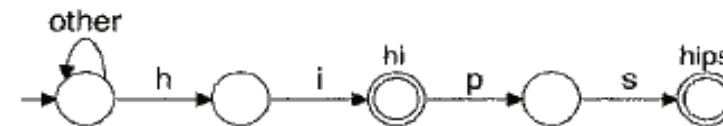
- When virus scanning, search for virus signature, which is bit string
- For simplicity, illustrate algorithm using English words
- For our example...
- Scan for any of the following words:
 - hi, hips, hip, hit, chip

Aho-Corasick: Building a Trie

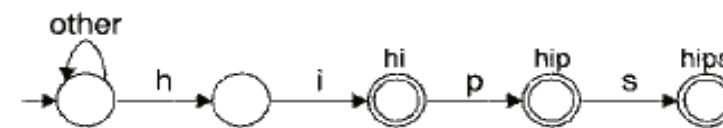
- Labels added in breadth-first order
- Closest to root get smallest numbers



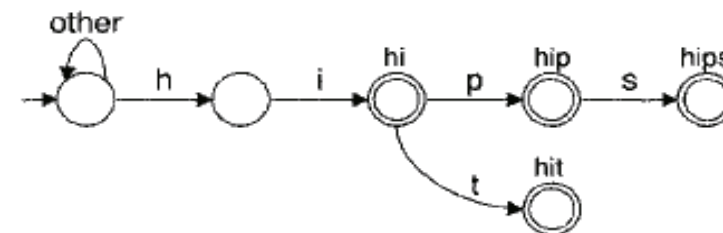
Added
hi



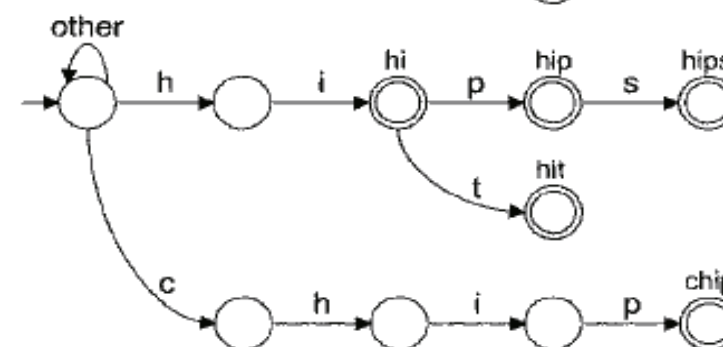
Added
hips



Added
hip



Added
hit



Added
chip

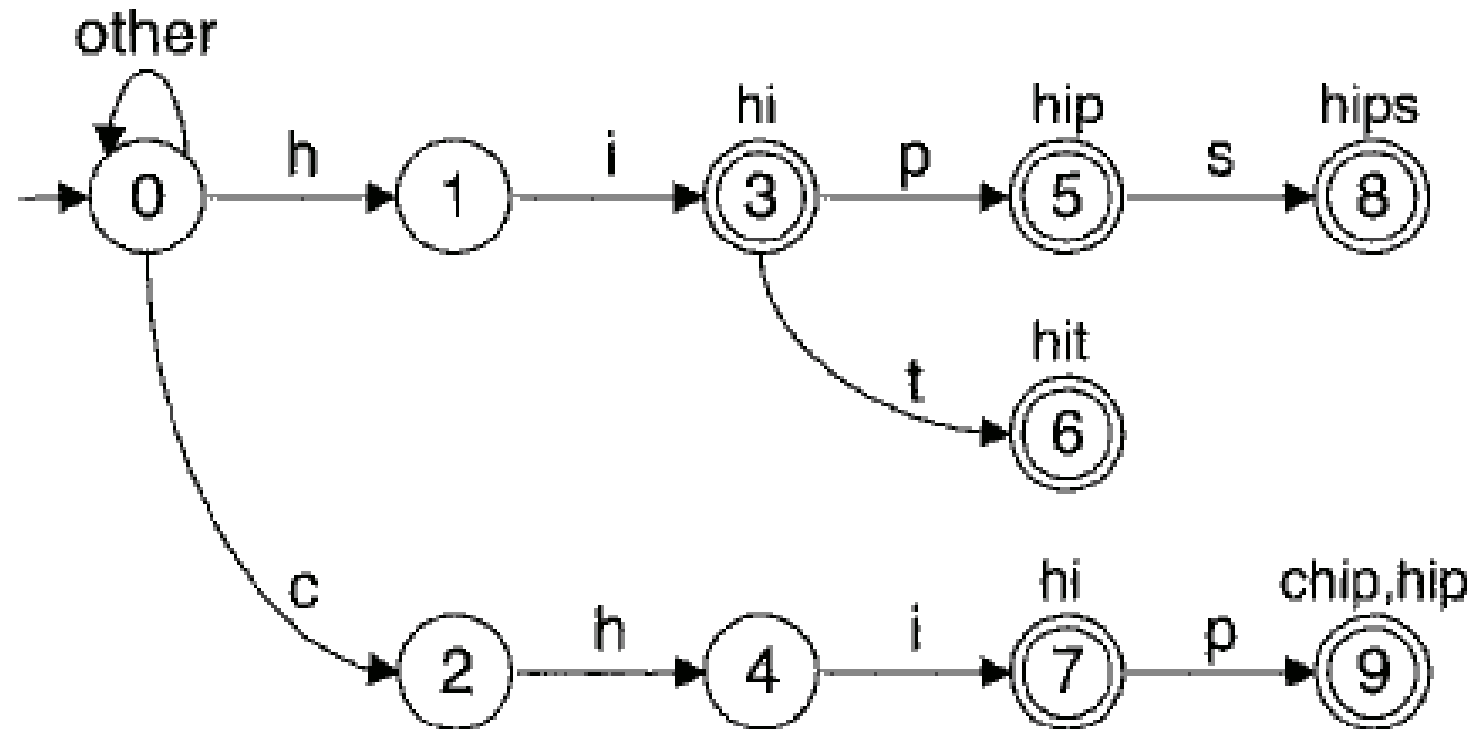
Aho-Corasick: Failure Function



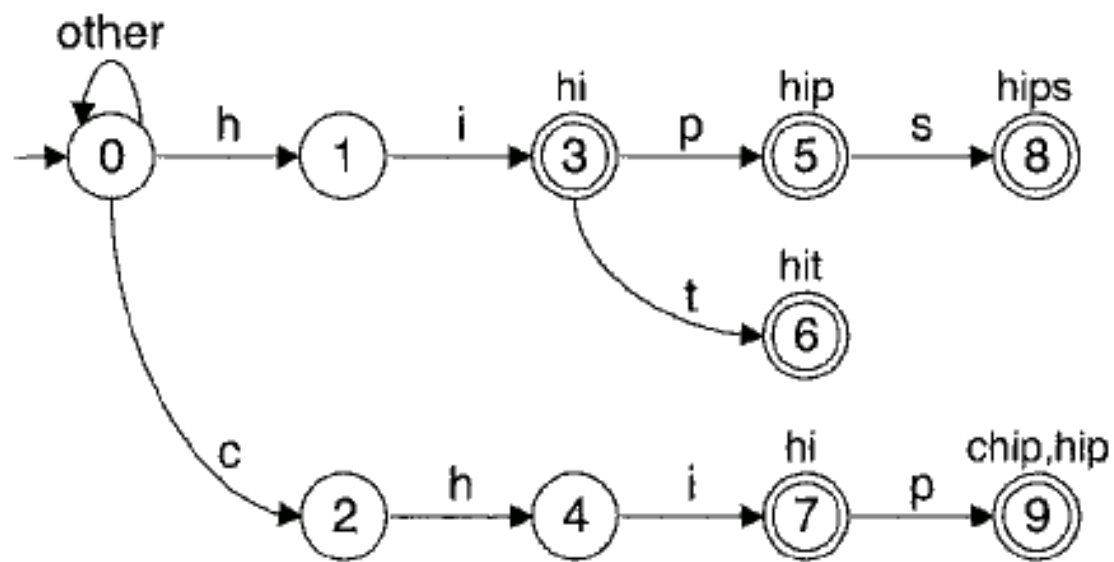
MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Depth 1 nodes
 - Fail goes back to start state
- For other states
 - Go back to earliest place where search can resume

Algorithm: Aho-Corasick



state	1	2	3	4	5	6	7	8	9
failure(state)	0	0	0	1	0	0	3	0	5



state	1	2	3	4	5	6	7	8	9
failure(state)	0	0	0	1	0	0	3	0	5

Aho-Corasick Example

Question2: c h i t
 0 2 1 3 6
 0 2 4 7 6

m i c r o c h i p s
 0 0 0 2 0 0 2 4 7 9 8

hi chip, hip hips

Improving Performance

- “Grunt scanning” --- scan everything
 - Slow slow slow
- Search only beginning and end of files
- Scan code ***entry point***
 - And points reachable from entry point
- If position of virus in file is known...
 - Make it part of the “signature”
- Limit scans to size of virus(es)



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Improving Performance

- Only scan certain types of files
 - Not so viable today
- Only rescan files that have changed
 - How to detect change?
 - File size? Modified date? ...



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Disinfect

- Disinfect == remove infection
- Not always possible to return file to it's original state
 - E.g., file might have been overwritten
- Disinfection methods...
- Delete the infected file
 - Pros and cons?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Operating systems hardening and Buffer Overflow Attacks

materials are partly from security courses at other institutions

OS Hardening



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY

How people see my application



How I see my application



What is OS hardening?

- Hardening process that includes planning, installation, configuration, update, and maintenance of the operating system and the key applications in use.
- OS architecture:

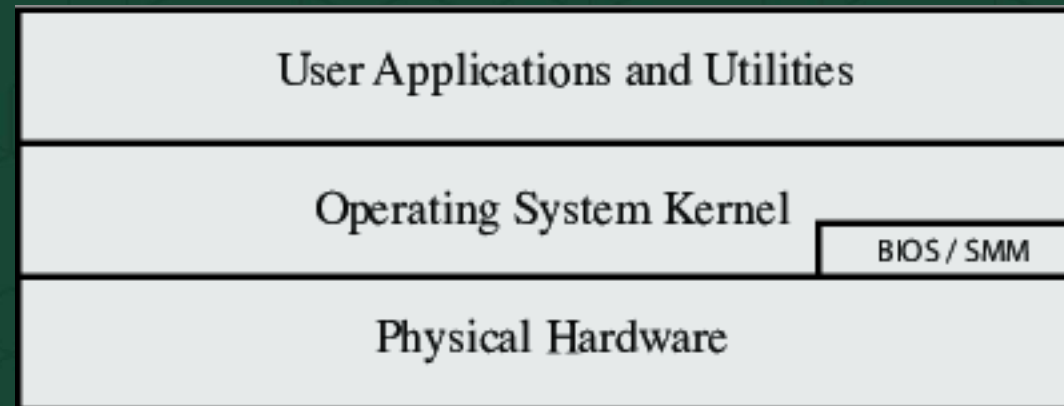
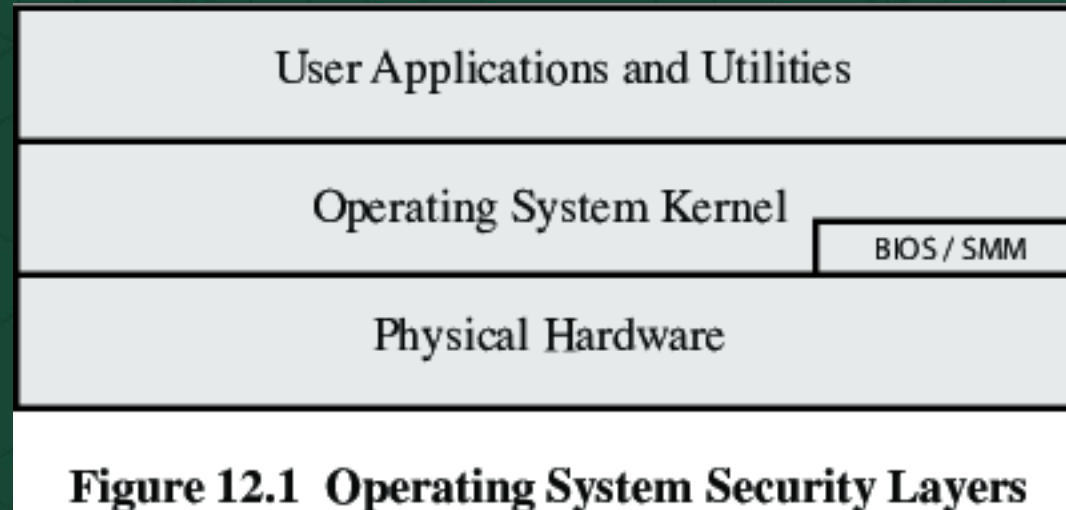


Figure 12.1 Operating System Security Layers

What is OS hardening?



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —



- Each of these layers of code needs appropriate hardening measures in place to provide appropriate security services. And each layer is vulnerable to attack from **below**, should the lower layers not also be secured appropriately. Is the same true from above?

can attacks also move downward from higher layers?

Things to consider during enterprise hardening

- The **purpose of the system**, the type of information stored, the applications and services provided, and their security requirements.
- The **categories of users** of the system, the privileges they have, and the types of information they can access.
- How the users are **authenticated**.
- How **access** to the information stored on the system is managed.
- What access the system has to **information stored on other hosts**, such as file or database servers, and how this is managed.
- **Who will administer** the system, and how they will manage the system (via local or remote access).
- Any additional security measures required on the system, including the use of host **firewalls**, anti-virus, or other malware protection mechanisms, and logging.

System hardening



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- **Hardware** is the most important layer (in some ultimate context, maybe not a practical one), but a compromise at any layer is sufficient to break any of the CIA triad.
- Lower levels can control or weaken higher layers, but the inverse is not always true.
- Applications and software are easier to verify, design, and program, and are more likely to be open-source.
- Hardware is much less accessible, and manufacturing details are kept secret.
- Most hardware is not open-source, e.g.,
 - Intel chips, firmware blobs, closed BIOS.
 - For an alternative, see IBM's power8, openmoko, and new RISC chips, etc.

Operating system hardening



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Overview:
- **Install** and **patch** the operating system.
- Harden and configure the operating system to adequately address the identified security needs of the system by:
 - **Removing unnecessary services**, applications, and protocols.
 - Configuring **users, groups, and permissions**.
 - Configuring resource controls.
- Install and configure additional security controls, such as host-based **firewalls** or intrusion detection systems (IDS), if needed.
- **Test** the security of the basic operating system to ensure that the steps taken adequately address its security needs!

Secure installation procedures



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- System security **begins with the installation** of the operating system.
- **Check hash** of install media to insure validity
- **Encrypt full hard disk** during installation
- Install only the **minimum needed software**
- Install in an **isolated environment** (OS is vulnerable until patched)
- Setup BIOS boot and configuration password
- **Avoid installing non-open binary** drivers, especially with kernel access
- **Patch** operating system to most current, and enable updates

Minimize base install

- Minimizing attack surface
- Ideally, install only the **minimum installed software** needed
- However, if a standard install is required, then **remove extras**
- Further, **disable any unneeded protocols and services!**



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

Users, Groups, Authentication



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Determine the needed permissions for each user of the system
- Map user permissions to groups of users
- Minimize the time that administrators will work under the state of elevated privilege
- **Remove any default or guest accounts, change any default passwords!!!**

Buffer Overflow Attack



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLAND W. BARNETT —

- One of the most common software and OS bugs is a buffer overflow
- The developer fails to include code that checks whether an input fits into its buffer array
- An input to the running process exceeds the length of the buffer
- The input string overwrites a portion of the memory of the process
- Causes the application to behave improperly and unexpectedly

History



MISSOURI UNIVERSITY OF
SCIENCE AND TECHNOLOGY
— ROLLA, MISSOURI —

- Buffer overflow attack history

1988	The Morris Internet Worm uses a buffer overflow exploit in "fingerd" as one of its attack mechanisms.
1995	A buffer overflow in NCSA httpd 1.3 was discovered and published on the Bugtraq mailing list by Thomas Lopatic.
1996	Aleph One published "Smashing the Stack for Fun and Profit" in <i>Phrack</i> magazine, giving a step by step introduction to exploiting stack-based buffer overflow vulnerabilities.
2001	The Code Red worm exploits a buffer overflow in Microsoft IIS 5.0.
2003	The Slammer worm exploits a buffer overflow in Microsoft SQL Server 2000.
2004	The Sasser worm exploits a buffer overflow in Microsoft Windows 2000/XP Local Security Authority Subsystem Service (LSASS).